

4

CORRIGIDAS & BLINDADAS

1

P1 CRÍTICA RESTANTE

5

P1 & P2 ALTAS

11

P3 MÉDIAS, BAIXAS E INFO

SEÇÃO 1: Vulnerabilidades Críticas Corrigidas e Publicadas (P0 + Bônus)

✓ VULN-03 — Regras do Firestore da Smart TV (NOC Videowall)

CORRIGIDA & PUBLICADA

Arquivo: firestore.rules (Seção 10)

CWE: CWE-862 (Missing Authorization)

OWASP: A01:2021 (Broken Access Control)

Cenário Anterior: A coleção tv_pairing_requests possuía allow read, create, update: if true;, permitindo que atacantes remotos autorizassem TVs fraudulentas ou realizassem DoS por escrita em massa.

Mitigação Aplicada: Criação restrita com validação de status estrito PENDING sem tokens. Atualização e autorização limitadas exclusivamente a técnicos autenticados da TI (isStaff()) - @tiecia.com.br).

```
allow create: if request.resource.data.status == 'PENDING' && request.resource.data.code == code && !('deviceToken' in request.resource.data);
allow read: if true; // TV escuta aprovação
allow update: if isStaff(); // Apenas técnicos autorizam
```

✓ VULN-02 — Bridge de Segurança com Falha Silenciosa

CORRIGIDA

Arquivo: use-mock-auth.tsx (Linhas 80-116)

CWE: CWE-284 (Improper Access Control)

OWASP: A01:2021 (Broken Access Control)

Cenário Anterior: A função activateBridge() capturava erros de indisponibilidade da API NestJS e definia isBridgeReady = true sem contingência segura.

Mitigação Aplicada: O estado de segurança é controlado rigorosamente (isBridgeReady = false em exceções críticas) e operando sob contingência Zero-Trust direta no Firestore.

✓ VULN-04 — Logs de Auditoria ISO 27001 com Identidade Falsificável

CORRIGIDA

Arquivo: audit-logger.ts (Linhas 74-106)

CWE: CWE-117 (Improper Output Neutralization for Logs)

OWASP: A09:2021 (Logging Failures)

Cenário Anterior: A função logAuditEvent() continha e-mails hardcoded (admin@empresa.com), comprometendo o não-repúdio e a trilha forense.

Mitigação Aplicada: Captura dinâmica do usuário autenticado no Firebase Auth (auth.currentUser) e suporte a parâmetros explícitos de auditoria com IP público, geolocalização e protocolo #2026XXXX.

✓ VULN-08 (Bônus) — Geração de Token Criptográfico para Smart TV

CORRIGIDA

Arquivo: tv-device-auth.ts (Linhas 149-180)

CWE: CWE-330 (Insufficiently Random Values)

OWASP: A02:2021 (Cryptographic Failures)

Mitigação Aplicada: Substituído Math.random() por crypto.randomUUID() / Web Crypto API e integrado registro de auditoria com o nome/e-mail real do técnico autorizador.

📄 SEÇÃO 2: Apontamentos Restantes por Nível de Prioridade (17 Itens)

● PRIORIDADE 1 (P1) — Alta Prioridade (Esta Semana)

ID	VULNERABILIDADE	LOCAL / ARQUIVO	IMPACTO & AÇÃO RECOMENDADA
VULN-01	Chaves Firebase Expostas OWASP A07:2021	apps/web/src/lib/firebase.ts	Chaves visíveis no bundle JS. Ação: Aplicar restrição HTTP Referrer no Google Cloud Console e ativar Firebase App Check com reCAPTCHA Enterprise.
VULN-05	RBAC no Frontend OWASP A01:2021	apps/web/src/hooks/use-mock-auth.tsx	Permissões manipuláveis via DevTools. Ação: Reforçar validação de Custom Claims no backend NestJS em todas as rotas de API.

● PRIORIDADE 2 (P2) — Backend & Autenticação (Próximo Sprint)

ID	VULNERABILIDADE	LOCAL / ARQUIVO	IMPACTO & AÇÃO RECOMENDADA
VULN-06	Cookies sem CSRF CWE-352	apps/api/src/core/auth/auth.controller.ts	Falta de token anti-CSRF em requisições POST. Ação: Implementar cabeçalho X-CSRF-Token e cookies sameSite: 'strict'.
VULN-07	SSO Open Redirect CWE-601	apps/api/src/core/auth/auth.controller.ts	Redirecionamento pós-SSO sem validação de state. Ação: Validar FRONTEND_URL contra lista de domínios confiáveis.
VULN-09	Endpoint sem DTO CWE-307	apps/api/src/core/auth/auth.controller.ts	POST /auth/portal-token sem validação estrita. Ação: Criar DTO com class-validator e decorator @Throttle(5, 60).
VULN-10	Auto-Provisioning SSO CWE-863	apps/api/src/core/auth/auth.service.ts	Novos usuários SSO tornam-se ativos de imediato. Ação: Provisionar com isActive: false aguardando aprovação do administrador.

● PRIORIDADE 3 (P3) — Melhorias, Hardening & Informativas

ID	VULNERABILIDADE	LOCAL / ARQUIVO	DESCRIÇÃO SINTÉTICA
VULN-11	WAF no Frontend	waf-corporate-filter.ts	WAF da UI é cosmético; a proteção real deve residir no backend / Cloudflare.
VULN-12	Rate Limit no Frontend	rate-limiter.ts	Rate limit local baseado em localStorage pode ser resetado pelo usuário.
VULN-13	Sanitização KB (SVG XSS)	sanitize.ts	Bloquear payloads data:image/svg+xml na Base de Conhecimento.
VULN-14	Senhas no .env	.env	Substituir templates change_me_* por segredos fortes em produção.
VULN-15	Tokens em localStorage	api-client.ts	Migrar JWTs para cookies HttpOnly para blindagem contra XSS.
VULN-16	Restauração de Sessão	use-mock-auth.tsx	Reforçar verificação de operador inativo durante falhas de rede transitórias.
VULN-17	Bypass Domínio TIÉCIA	use-mock-auth.tsx	Padronizar cadastro de domínios corporativos diretamente na coleção domains.
VULN-18	Bloqueador F12	main.tsx	Remover dependência de bloqueio client-side contra abertura de DevTools.
VULN-19	Contadores #2026XXXX	firestore.rules	Restringir incremento de contadores para evitar colisão proposital.
VULN-20	Projetos Compartilhados	firebase.ts	Documentar a separação lógica de coleções no mesmo projeto GCP.
VULN-21	Logs em Produção	use-mock-auth.tsx	Remover chamadas de console.info em builds de produção.